MK FRAUD INSIGHTS

FRAUD READINESS · ESSENTIAL

# Fraud Readiness Report

## Fictional Owner-Managed Firm

Assessment reference FX-P4

12 November 2026

Confidential. Prepared for the management of Fictional Owner-Managed Firm.

Fictional prototype for MK review. The organisation is fictional, calculated figures are labelled test results, and this is not a customer report or a certified paid report.

# About this report

This report sets out what the firm's own answers establish about its fraud controls, what that means for its owners and management, and what should happen first. It begins with the overall position, explains the patterns behind it, develops the findings that need attention, shows how fraud could exploit them, and closes with the first responses and a ninety-day plan. The supporting workbook carries the complete registers and the detailed control specifications.


| | | |
|---|---|---|
| EXECUTIVE SUMMARY | The firm has its fraud basics in place, and its exposure sits almost entirely in email, calls and sign-in | 3 |
| READINESS PROFILE | Five areas report every control in place, and every gap falls in digital and identity fraud | 5 |
| WHAT IS DRIVING THE POSITION | Three patterns drive the position, and the weakness is narrow enough to close quickly | 6 |
| THE FINDINGS THIS REPORT DEVELOPS | Seven findings show where an outsider could reach the firm's money or information | 8 |
| | Instructions by phone, voice note or video are checked only at individual discretion | 8 |
| | A compromise of personal information would be handled without a set process | 8 |
| | Payment instructions received by email are acted on as received | 9 |
| | Email accounts are protected by passwords only | 9 |
| | Help desk resets are usually, but not always, verified | 10 |
| | The systems that move money can be entered with a password | 10 |
| | Access to personal information is limited for some systems only | 11 |
| HOW FRAUD EXPOSURE COULD MATERIALISE | The open controls create three routes by which an outsider could take money from the firm or its clients | 12 |
| WHAT MANAGEMENT SHOULD DO FIRST | Six controls come first, and most of them can be in place within weeks | 14 |
| A 30, 60 AND 90 DAY RESPONSE | The first ninety days close the access routes and put the verification rule to work | 15 |
| BASIS OF THIS REPORT | This report rests on the firm's own answers, read against MK's method | 16 |
| MANAGEMENT CONCLUSION | The firm's controls are sound where it has looked, and the next ninety days should extend them to its inboxes and sign-ins | 18 |

EXECUTIVE SUMMARY

# The firm has its fraud basics in place, and its exposure sits almost entirely in email, calls and sign-in

On its own answers, the firm reports the core controls in place for 37 of the 49 fraud scenarios that apply to an organisation of its size and activity, and a core control reported as a gap in 10. A further two scenarios are not expected of a firm this size, and are not counted against it.

The position is strong in most respects and specific in its weakness. In fraud governance, fraud risk assessment, ethics, finance and banking, and detection and response, every core control is reported in place. Every one of the gaps falls in a single area, digital, cyber-enabled and identity fraud, where none of the 10 scenarios that apply has its core control in place.

Three patterns explain this. The first is that the firm has built the fraud controls that matter for a business of its size: ownership, a risk assessment, ethical standards, sound finance and banking practice, and a way to report and respond. The second is that its exposure is concentrated in how it communicates and signs in: email accounts protected by passwords alone, payment instructions acted on as received, calls and voice notes checked only at someone's discretion, and systems that move money accessible with a password. The third connects them: across those channels, a request is accepted on the strength of the request itself.

In fraud terms, that is the profile on which business email compromise and impersonation depend. A stolen email password is enough to enter a mailbox, read correspondence and send instructions from it. An email asking for a payment or a change of bank details is acted on as received. A call or voice note that sounds like the owner can instruct a payment, and the banking platform itself can be entered with a password. Each of these can move money out of the firm, or divert its income, without breaking any of the controls it already has.

The first responses are few and practical. Multi-factor sign-in on every email account and on every system that moves money, an organisation-wide rule that no payment or bank detail received by email is acted on without confirmation through a separate, known channel, and an agreed way to verify calls, voice notes and video that applies to everyone including the owners. Alongside these, the firm needs a set procedure for notifying the Information Regulator and the people affected if personal information is compromised, as POPIA requires, and help desk resets verified through a route the caller does not control.

Every question in the assessment was answered, so the position is not limited by missing information.

## WHAT THE ASSESSMENT ESTABLISHES

### CALCULATED TEST RESULT

**78.5 of 100** TEST FIXTURE

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

### UNRESOLVED INCONSISTENCIES

**None found**

None found in the 1 pair of answers compared. Most related practices were not asked, so this is not a finding that every answer is consistent.

### PROVISIONAL MANAGEMENT INTERPRETATION

**10 with a control reported as a gap**

On its own answers, the organisation reports the core control in place for 37 of the 49 fraud scenarios that apply; and 10 have a core control reported as a gap.

### APPROVED READINESS CONCLUSION

**None issued**

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

READINESS PROFILE

# Five areas report every control in place, and every gap falls in digital and identity fraud

The profile shows how the fraud scenarios in each of the six areas that apply to the firm divide between controls reported in place and controls reported as gaps. In five areas every core control is reported in place: fraud governance and accountability, fraud risk assessment, ethics, integrity and anti-corruption, finance, banking and financial reporting and detection, speak-up and response.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

| AREA | SCENARIOS THAT APPLY | CORE CONTROLS IN PLACE | TEST FIGURE |
|---|---|---|---|
| Fraud governance and accountability | | 11 of 11 | 90.0 |
| Fraud risk assessment | | 6 of 6 | 91.7 |
| Ethics, integrity and anti-corruption | | 6 of 6 | 86.7 |
| Finance, banking and financial reporting | | 6 of 6 | 100.0 |
| Assets, cash and inventory | | 0 of 0 | |
| Digital, cyber-enabled and identity fraud | | 0 of 10 | 16.0 |
| Detection, speak-up and response | | 8 of 8 | 86.7 |

Core controls reported in place · In place, related practice weaker · Answers to settle or clarify · Core control reported as a gap

Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

The remaining area, digital, cyber-enabled and identity fraud, is open in every scenario that applies to it. The contrast is unusually sharp, and it points to a firm whose financial and ethical controls are well established but whose fraud thinking has not yet extended to the channels through which most modern fraud against small organisations arrives.

WHAT IS DRIVING THE POSITION

# Three patterns drive the position, and the weakness is narrow enough to close quickly

The profile shows where the gaps lie. The patterns below explain what they mean, and each ends with what it asks of the owners.

ACROSS THE ORGANISATION

## The core fraud framework is in place for a firm of this size

Ownership of fraud risk is written into a named role, the risks are assessed, ethical standards are set, finance and banking controls are described as working, and there is a way to report and respond to concerns. For a firm with fewer than fifty people, that is a sound foundation, and many organisations of this size have nothing comparable.

The implication is that the firm does not need a fraud programme built from the beginning. It needs to extend the discipline it already applies to its finances into its communications and systems.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## The exposure is concentrated in email, calls, sign-in and personal information

All 10 scenarios with a control reported as a gap sit in digital and identity fraud. Email and the systems that move money are protected by passwords alone, payment instructions received by email are acted on as received, calls and voice notes are verified at individual discretion, and there is no set process for notifying a compromise of personal information.

These are the channels through which an outsider reaches a small firm. A fraudster does not need to defeat the firm's finance controls if they can send an instruction from its own mailbox, or call in a voice the firm trusts. The concentration is therefore more significant than the count suggests, because it affects the route by which instructions reach the controls that are in place.

The owners should treat this area as the first and main programme of work, with whoever manages the firm's IT, whether in-house or provided externally, accountable for the technical controls.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Requests are accepted on the requester's word

Across the digital area, 4 practices that would verify a request through a route the requester does not control are reported weaker than in place: email instructions, calls and voice notes, changes to call-back details, and help desk resets.

Most impersonation fraud succeeds by supplying the confirmation a process asks for, a reply from the mailbox, a familiar voice or a convincing story to the help desk. The defence is a single rule, applied to everyone including the owners: confirm through details already held and a channel the requester did not choose. For a firm of this size, one rule, briefed to everyone, is both practical and effective.

THE FINDINGS THIS REPORT DEVELOPS

# Seven findings show where an outsider could reach the firm's money or information

The findings below are the scenarios through which each pattern appears most clearly, chosen within each theme for more core controls reported absent or more related practices also reported weaker. They follow the method's order, which is not a ranking; The full register of 11 findings is in the supporting workbook.

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Instructions by phone, voice note or video are checked only at individual discretion

Some staff check unusual requests made by phone, voice note or video, depending on their own judgement. Treating pressure as a trigger to verify, verifying changes to call-back details and banning requests for gift cards or PINs are each only partly in place.

In a small firm, the owners' voices are known to everyone, which makes them easy to trust and, now, easy to imitate from a short recording. A check that depends on judgement is skipped exactly when the caller applies urgency or rank.

The firm should agree one verification method, such as a call-back on a known number or a code word, that applies to every such request and to everyone, including the owners.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Verification for calls, voice notes and video: partly in place | Chief financial officer | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## A compromise of personal information would be handled without a set process

A security compromise would be handled as it happens, without a set process, and warning the people affected is not in place.

POPIA requires the Information Regulator and the people affected to be notified as soon as reasonably possible after a compromise is discovered. Without a procedure, the decision about whether and when to notify would be made under pressure, and the people affected

could not protect themselves in time.

The firm should set out who decides, who notifies the Regulator and the people affected, and how quickly, and test the procedure once a year.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Compromises reported as POPIA requires: partly in place | IT lead | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Payment instructions received by email are acted on as received

Payment changes received by email are acted on as received, and there is no rule requiring confirmation through a separate, known channel.

This is the point at which business email compromise succeeds. Whether the email comes from a spoofed address or from a genuine mailbox that has been taken over, an instruction acted on without separate confirmation will be paid.

The firm should adopt a rule that no payment, salary or bank detail received by email is acted on without confirmation through a separate, known channel, and brief everyone on it.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Email never enough on its own: not in place | Chief financial officer | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Email accounts are protected by passwords only

Email accounts, including the owners' and shared mailboxes, are protected by passwords alone.

Most business email compromise begins with an account that has no second factor. A password obtained through phishing, or reused from another website, gives an outsider the mailbox itself: its correspondence with clients and suppliers, and the ability to send from it.

Multi-factor sign-in on every email account, with no exceptions, is the single control that closes this route.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Multi-factor on all email: not in place | IT lead | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Help desk resets are usually, but not always, verified

Most password and multi-factor resets need verification through a trusted route, such as a manager or a number on file.

The reset is how an impersonator turns a convincing story into access. A reset that is verified most of the time is the one an attacker will look for, typically by claiming a lost phone and pressing for urgency.

Every reset should be verified through a route the caller does not control, whoever handles the firm's IT.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Help desk resets verified: partly in place | IT lead | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## The systems that move money can be entered with a password

Remote access, cloud systems and the banking platform are protected by passwords only.

A password for the banking platform, obtained by phishing or taken from a compromised mailbox, would let an outsider change beneficiaries or release payments in the firm's name. The strength of the firm's payment approvals matters less if the system that executes them can be entered this easily.

Multi-factor sign-in should be required for remote access, cloud systems, the banking platform and any system that can move money or change master data.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Multi-factor on critical systems: not in place | IT lead | 60 days (proposed) |

DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## Access to personal information is limited for some systems only

Access to personal information is limited to the people who need it for some systems only, and bulk exports are not consistently restricted.

Personal information held by the firm is valuable to fraudsters, both to sell and to make impersonation of the firm's clients more convincing. The wider the access, the larger the loss if a single account is compromised.

The firm should limit access to personal information in every system to the people who need it and restrict bulk exports. The control is specified in the workbook.

| POSITION | CORE CONTROL | OWNER | FIRST RESPONSE |
|---|---|---|---|
| A core control reported as a gap | Access to personal information limited: partly in place | Legal and compliance lead | In the workbook action register |

HOW FRAUD EXPOSURE COULD MATERIALISE

# The open controls create three routes by which an outsider could take money from the firm or its clients

The findings combine. In each pathway below, one weakness gives an outsider access and another lets the instruction through. They are plausible sequences built from the answers and MK's scenario library; they do not suggest that any of these events has occurred.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## An email account is taken over and the firm's own invoices are used to divert its income

An outsider obtains the password to a staff mailbox, through a phishing message or a password reused elsewhere. Because the mailbox has no second factor, the password is enough to sign in.

The outsider watches the firm's correspondence with clients and, at the right moment, sends an invoice or notice with changed bank details from the firm's real address. Clients have no reason to doubt it. The firm discovers the fraud when expected payments do not arrive, by which time its clients have paid the outsider and its relationships with them are damaged.

WARNING SIGNS

- Clients querying a change of bank details
- Unfamiliar sign-ins or forwarding rules on a mailbox
- Sent messages the owner did not write
- A drop in expected receipts

FIRST RESPONSE

Reset the account and remove any forwarding rules, notify clients through a known channel, and preserve the sign-in and message logs.

LASTING CONTROL

Every email account is protected by multi-factor sign-in, and clients are told how the organisation will confirm any change of bank details.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## A cloned voice of an owner instructs an urgent payment

An outsider uses a short public recording of one of the owners to imitate their voice, and calls or sends a voice note asking for an urgent, confidential payment.

The request comes from a voice everyone knows, and the check depends on whoever takes the call. Under urgency and rank, the payment is made. It appears properly authorised until the owner is asked about it.

**WARNING SIGNS**

- An instruction that insists on secrecy or bypasses the normal process
- Urgency with a reason why the executive cannot be called back
- A request from an unfamiliar number or account
- A new beneficiary on an executive instruction

**FIRST RESPONSE**

Call the executive back on a known number, contact the bank to recall the payment, and preserve the call, message and payment records.

**LASTING CONTROL**

An agreed verification method applies to every request made by phone, voice note or video, to everyone including executives, and staff are expected to use it.

FRAUD PATHWAY · DIGITAL, CYBER-ENABLED AND IDENTITY FRAUD

## A payment instruction received by email is acted on without separate confirmation

An outsider sends an email that appears to come from a supplier or an owner, asking for an urgent payment or a change of bank details, timed for when the supposed sender is hard to reach.

Because email instructions are acted on as received, the payment is processed in the ordinary way. The fraud is found only when the supposed sender is asked, and recovery depends on how quickly the bank is alerted.

**WARNING SIGNS**

- Urgency and a reason why the sender cannot be reached
- A new beneficiary or changed bank details
- A slightly different email address
- An instruction to keep the request confidential

**FIRST RESPONSE**

Contact the bank to recall the payment, confirm with the supposed sender through a known number, and preserve the email and payment records.

**LASTING CONTROL**

Every payment, salary or urgent request received by email is confirmed through a separate, known channel before it is acted on.

WHAT MANAGEMENT SHOULD DO FIRST

# Six controls come first, and most of them can be in place within weeks

The first responses close the routes described above. Several are settings rather than projects, and none requires new systems beyond what a firm of this size already uses. The full specification for each, including its records and failure response, is in the supporting workbook.

FIRST RESPONSES

| RESPONSE | ACCOUNTABLE EXECUTIVE | PRACTICAL OWNER | PROPOSED STAGE | SUCCESS MEASURE |
|---|---|---|---|---|
| **Verification for calls, voice notes and video** | Chief financial officer | Chief financial officer | 60 days | All staff who act on requests by phone, voice note or video were briefed by the end of the period, and the most recent test found the rule followed in every case tested, including requests that appeared to come from executives. |
| **Compromises reported as POPIA requires** | Chief financial officer | IT lead | 60 days | In the period, the procedure was tested or used, and every compromise discovered was notified as soon as reasonably possible, with any delay justified and recorded. |
| **Email never enough on its own** | Chief financial officer | Chief financial officer | 60 days | All staff who act on payment or salary requests were briefed by the end of the period, and the most recent test found the rule followed in every case tested. |
| **Multi-factor on all email** | Chief financial officer | IT lead | 60 days | At the end of the period, the email security report shows multi-factor authentication on every email account, including executives' and shared mailboxes, and any exception is approved and recorded. |
| **Help desk resets verified** | Chief financial officer | IT lead | 60 days | Every password or multi-factor reset made in the period was confirmed through a route the caller did not control before it took effect, or is a recorded and approved exception. |

| RESPONSE | ACCOUNTABLE EXECUTIVE | PRACTICAL OWNER | PROPOSED STAGE | SUCCESS MEASURE |
|---|---|---|---|---|
| **Multi-factor on critical systems** | Chief financial officer | IT lead | 60 days | At the end of the period, the multi-factor coverage report shows multi-factor authentication on remote access, cloud systems, the banking platform and every system that can move money or change master data, and any exception is approved and recorded. |

Responses are listed in the order the work should start, which is not a ranking of fraud risk. Stages are proposals for management's own plan, not deadlines. Full specifications, records and failure responses are in the supporting workbook.

An agreed verification method for calls, voice notes and video, applying to everyone including the owners, and a rule that no email instruction is acted on without separate confirmation, together close the impersonation routes. The chief financial officer owns both.

Multi-factor sign-in on every email account and on every system that moves money closes the routes by which an outsider gains access in the first place. Whoever manages the firm's IT owns them, and the measure is simple: full coverage, confirmed at the end of each period, with any exception approved.

A notification procedure for compromises of personal information, and verification of every help desk reset, complete the first set. The first protects the people whose information the firm holds; the second closes the gap through which a reset becomes access.

A 30, 60 AND 90 DAY RESPONSE

## The first ninety days close the access routes and put the verification rule to work

The plan sets out three proposed stages. The windows are proposals for the firm's own plan; they are not deadlines, contractual dates or estimates. A control can be said to work only once it has met its success measure over a full operating cycle.

THE FIRST NINETY DAYS, IN PROPOSED STAGES

## 30 days

PROPOSED STAGE

Name the owners, decide the order of work and approve the designs to be built.

- Each open area has a named accountable executive
- The order of work is recorded with the factors behind it

OWNERS

Chief executive

## 60 days

PROPOSED STAGE

Approve the design, owner and record for each priority control, and schedule its first operating cycle.

- Verification for calls, voice notes and video
- Compromises reported as POPIA requires
- Email never enough on its own
- Multi-factor on all email
- Help desk resets verified
- Multi-factor on critical systems

OWNERS

Chief financial officer, IT lead

## 90 days

PROPOSED STAGE

Start operating the priority controls and report status to the oversight body.

- Each priority control has run at least once and kept its record
- Status reported to the owners

OWNERS

Chief executive, Chief financial officer, IT lead

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

In the first thirty days, the owners name who is accountable for the digital area and record the order of work. By sixty days, multi-factor sign-in, the verification rule and the reset procedure should be designed and switched on, with the notification procedure written. By ninety days, each should have run, the verification rule should have been briefed to everyone and tested, and the owners should receive a short status report.

BASIS OF THIS REPORT

# This report rests on the firm’s own answers, read against MK’s method

Every finding rests on answers given by the firm’s respondent. MK has not examined documents, interviewed staff or tested any control, and the records named in the report are records the firm should keep rather than evidence MK has reviewed. Independent examination of whether controls operate belongs to MK Advisory, which is scoped and priced separately.

Scenarios the method does not expect of a firm this size are excluded rather than counted as gaps. Answers given as “not known” would be reported as outstanding and never as weaknesses; none remained.

The position is stated in four parts with the executive summary: what was calculated, what is inconsistent, how the answers read and what MK concludes. Findings and responses are selected and ordered by the rules stated where they appear, not by a ranking of fraud risk.

**PROTOTYPE NOTICE: WHAT A RELEASED REPORT ADDS**

| ELEMENT | IN A RELEASED REPORT | IN THIS EDITION |
|---|---|---|
| **Readiness conclusion** | Issued under MK's approved readiness method, with the score and level that method defines. | Calculated result shown as a labelled test fixture; no level or band issued (decision D-1). |
| **Order of work** | Set by MK's approved decision method. | Ordered by the explicit factors stated in the report, a candidate method (decision D-3). |
| **Control specifications, pathways and decision options** | MK-approved advisory content. | Draft content from MK's control-content library, scenario structures and decision options (decision D-5). |
| **Manuscript** | Written by the production AI writer from this fact pack, then validated. | Written in-session under the same writer contract and validated by the same checks; the production AI run is a blocked acceptance test. |

MANAGEMENT CONCLUSION

# The firm’s controls are sound where it has looked, and the next ninety days should extend them to its inboxes and sign-ins

The firm should recognise that it has done the harder work already. Its fraud ownership, risk assessment, ethics, finance and response controls are reported in place, which gives it a foundation many small organisations lack. Its exposure lies in the channels through which instructions reach those controls: email, calls, voice notes and sign-in.

The changes that close that exposure are few and practical. Multi-factor sign-in everywhere money or mail can be reached, one verification rule that applies to everyone, a verified reset process, and a procedure for notifying a compromise of personal information.

Within ninety days, each of these should be switched on or written, briefed and tested, and the owners should have a short report showing which routes are closed. The firm would then have extended its existing discipline to the channels most likely to be used against it.

The sensible next step, once the controls are running, is a periodic check that they remain in force, particularly that no new mailbox or system has been added without a second factor, and a review of the remaining scenarios in the register.

# Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Fictional Owner-Managed Firm on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Fictional prototype for MK review; not a customer report.